OXLY · ORIENTIERUNG

NIS2 Schnellcheck - 10 Fragen

Für Geschäftsleitung und Beauftragte im deutschen Mittelstand

Version 1.0
Stand: November 2026
oxly-compliance.de

Diese Liste hilft, offene Punkte im Unternehmen sichtbar zu machen. Sie ist keine Rechtsberatung, kein Bescheid und kein Ersatz für den amtlichen Wortlaut oder für die offizielle Betroffenheitsprüfung des BSI. Maßgeblich sind die NIS-2-Richtlinie (EU) 2022/2555, das NIS-2-Umsetzungsgesetz und das BSI-Gesetz (BSIG) sowie die KI-Verordnung (EU) 2024/1689. Einsichtnahme der zugrunde gelegten Vorschriften: 13. November 2026.

1 Sektor nach Anlage 1 oder 2 BSIG

Haben wir anhand des amtlichen Wortlauts geprüft, ob unsere Tätigkeit in einem erfassten Sektor liegt? Ausgangspunkt: Anlagen 1 und 2 zum BSIG sowie die Betroffenheitsprüfung des BSI.

☐ Ja ☐ Nein ☐ Unsicher

2 Größe und Sonderfälle

Erreichen wir die gesetzlichen Größenschwellen - in der Regel mindestens 50 Beschäftigte oder Jahresumsatz und Jahresbilanzsumme jeweils über 10 Millionen Euro; im Sektor hoher Kritikalität können höhere Schwellen zu einer besonders wichtigen Einrichtung führen -, oder greift ein Sonderfall (etwa KRITIS, bestimmte Vertrauensdienste, DNS/TLD, Telekommunikation)?

☐ Ja ☐ Nein ☐ Unsicher

3 Verbundene Unternehmen

Haben wir verbundene Unternehmen bei der Größenbetrachtung berücksichtigt? Maßgeblich sind in der Regel die Schwellen der Empfehlung 2003/361/EG, mit der Maßgabe des § 28 Absatz 4 BSIG. Im Zweifel unsicher ankreuzen und den Wortlaut prüfen.

☐ Ja ☐ Nein ☐ Unsicher

4 Anbieten von Waren oder Dienstleistungen

Bieten wir Waren oder Dienstleistungen an? Die sektoralen Schwellen des § 28 Absatz 1 Nummer 4 und Absatz 2 Nummer 3 BSIG knüpfen daran an. Sonderfälle können unabhängig davon gelten.

☐ Ja ☐ Nein ☐ Unsicher

5 Registrierung im BSI-Portal

Falls eine Betroffenheit in Betracht kommt: Ist die Registrierung über "Mein Unternehmenskonto" und das BSI-Portal erfolgt oder nachgeholt? Sie ist spätestens drei Monate nach dem erstmaligen oder erneuten Eintritt der Betroffenheit vorzunehmen. Für bereits am 6. Dezember 2025 Betroffene endete dieser Zeitraum am 6. März 2026. Änderungen sind unverzüglich, spätestens nach zwei Wochen, zu übermitteln.

☐ Ja ☐ Nein ☐ Unsicher

6 Kontaktstelle und Verantwortlichkeiten

Ist intern geklärt, wer als NIS-2-Kontaktstelle bzw. Kontaktperson dient und wer Risikomanagement sowie Meldewege verantwortet? Die Verantwortung für Umsetzung und Überwachung der Risikomanagementmaßnahmen liegt bei der Geschäftsleitung.

☐ Ja ☐ Nein ☐ Unsicher

So nutzen Sie diese Liste

Kreuzen Sie ehrlich an. Jedes "Unsicher" ist ein Arbeitsauftrag, kein Makel. Zuerst den amtlichen Wortlaut und die offizielle Betroffenheitsprüfung des BSI heranziehen. Die zehn Maßnahmenblöcke des § 30 Absatz 2 BSIG und konkrete nächste Schritte - einschließlich des kostenlosen Online-Checks - stehen auf Seite 2.

7 Risikomanagement nach § 30 BSIG

Sind die mindestens zehn Maßnahmenblöcke des § 30 Absatz 2 BSIG zumindest grob zugeordnet und dokumentiert? Verhältnismäßigkeit richtet sich nach Risikoexposition, Größe und Kosten. Die zehn Blöcke stehen in der Übersicht unten.

☐ Ja ☐ Nein ☐ Unsicher

8 Meldewege für erhebliche Sicherheitsvorfälle

Gibt es einen schriftlichen Weg, erhebliche Sicherheitsvorfälle dem BSI zu melden? Nach der Darstellung des BSI: 24 Stunden für die frühe Erstmeldung, 72 Stunden für eine weitere Meldung, 30 Tage für die Abschluss- bzw. Folgemeldung - jeweils nach Kenntniserlangung. Maßgeblich ist der Wortlaut des § 32 BSIG.

☐ Ja ☐ Nein ☐ Unsicher

9 Information und Schulung der Geschäftsleitung

Wird die Geschäftsleitung zu Cyber- und Informationssicherheitsrisiken so informiert und geschult, dass sie ihre gesetzliche Verantwortung wahrnehmen kann? In der Gesetzesbegründung gilt als "regelmäßig" ein Abstand von mindestens drei Jahren; das BSI hält dieses Mindestintervall in den seltensten Fällen für ausreichend.

☐ Ja ☐ Nein ☐ Unsicher

10 KI-Systeme und Rolle nach dem AI Act

Welche KI-Systeme setzen wir ein - auch gängige Office- oder Fachanwendungen mit KI-Funktionen? Sind wir eher Anbieter oder Betreiber? Greifen bereits geltende Pflichten, etwa zur KI-Kompetenz, zu Verboten oder zur Transparenz nach Artikel 50 der Verordnung (EU) 2024/1689 (seit 2. August 2026)?

☐ Ja ☐ Nein ☐ Unsicher

Die zehn Maßnahmenblöcke nach § 30 Absatz 2 BSIG (öffentlicher Mindestkanon)

Quelle: BSI, "NIS-2-Pflichten", in Anlehnung an § 30 Absatz 2 BSIG. Einsichtnahme: 13. November 2026. Dies ist eine Orientierung, keine abschließende Umsetzungsliste.

1. Konzepte zur Risikoanalyse und zur Sicherheit in der Informationstechnik
2. Bewältigung von Sicherheitsvorfällen (Incident Response)
3. Aufrechterhaltung des Betriebs (unter anderem Backup und Wiederherstellung) sowie Krisenmanagement
4. Sicherheit der Lieferkette, einschließlich sicherheitsbezogener Aspekte der Beziehungen zu unmittelbaren Anbietern
5. Sicherheitsmaßnahmen bei Erwerb, Entwicklung und Wartung, einschließlich Schwachstellenmanagement
6. Konzepte und Verfahren zur Bewertung der Wirksamkeit der Maßnahmen
7. Grundlegende Schulungen und Sensibilisierungsmaßnahmen
8. Konzepte und Prozesse für den Einsatz kryptographischer Verfahren
9. Personalsicherheit, Zugriffskontrolle und Verwaltung von IKT-Systemen, -Produkten und -Prozessen
10. Mehr-Faktor-Authentifizierung oder kontinuierliche Authentifizierung sowie gesicherte Kommunikation, gegebenenfalls Notfallkommunikation

Nächste Schritte - öffentlich, ohne Kaufpflicht

1. Offizielle Betroffenheitsprüfung des BSI: betroffenheitspruefung-nis-2.bsi.de
2. Kostenloser Online-Schnellcheck von Oxly (läuft nur im Browser): oxly-compliance.de/nis2-check.html
3. Amtlicher Wortlaut des BSIG: gesetze-im-internet.de/bsig_2025
4. Optional: NIS2 & AI Act Readiness Kit (Version 1.1, 97 € inkl. MwSt.): oxly-compliance.de

Das Kit enthält einen Leitfaden und 11 Vorlagen. Es ist ein Hilfsmittel zur Vorbereitung und ersetzt keine individuelle Beratung. Dieser Schnellcheck gibt die Inhalte des kostenpflichtigen Kit nicht wieder.